

Policy

POL-ISMS — Information Security Policy

Version 2.0.0 · approved · classification public

Document id	POL-ISMS
Type	Policy
Status	approved
Version	2.0.0
Classification	public
Owner	Information Security Officer / ISMS Manager (Alex Rossi)
Approver	Managing Director (Dana Weber)
Effective date	2025-09-01
Last reviewed	2025-09-01
Review cycle	1 year
Next review	2026-09-01
Applies to	all entities in scope
Annex A controls	A.5.1, A.5.4, A.5.35, A.5.36
ISO/IEC 27001 clauses	4.4, 5.1, 5.2, 5.3, 6.2, 7.1
Related documents	POL-ORG, PROC-RISK, PROC-MR, PROC-AUDIT, PROC-CAPA, PROC-DOC, POL-IR, POL-HR, POL-LEG

Digital signature. When this PDF is produced by the release pipeline it carries a PAdES signature of the ISMS document-control key, shown at the bottom of this page; verify it with `isms verify` or any PDF reader. An unsigned copy is not a controlled document.

Digital signature (PAdES) — applied by the release pipeline. An unsigned copy is not a controlled document.

Digitally signed by
ISMS Document Control - UNTRUSTED DEVELOPMENT KEY
2026-08-20 22:09:19 CEST
UNTRUSTED DEVELOPMENT KEY - not a controlled copy

Purpose

PaketPort operates parcel lockers that stand on public streets and a platform that holds the personal data of the people who use them and the handover data of the carriers who rely on them. This policy states top management's commitment to protecting that information and that service, sets the objectives of the information security management system (ISMS) and establishes the framework of policies, standards and procedures through which the commitment is carried out.

Scope

This policy applies to PaketPort Systems GmbH, PaketPort Deutschland GmbH and PaketPort Software s.r.o., to everyone who works for or on behalf of them, and to all information, systems, sites and services within the ISMS scope statement. The scope statement is generated from the organisation register and published with every release; the minority-held reseller PaketPort Italia S.r.l. is outside the scope and is treated as a third party.

Policy statements

Commitment and objectives

- **ISMS-1** PaketPort shall protect the confidentiality, integrity and availability of the information entrusted to it by consumers, carriers, site hosts, suppliers and staff, and the availability and integrity of the locker service, through an ISMS that conforms to ISO/IEC 27001:2022 and meets the group's duties under the NIS2 Directive.
- **ISMS-2** Top management shall set measurable information security objectives at each management review and provide the people, budget and tools needed to achieve them. The objectives for the current cycle are:

Objective	Measure	Target
No late regulatory reports	Significant incidents reported within the NIS2 Art. 23 deadlines	100 %
Everyone trained	Staff and field technicians with current awareness training	≥ 98 % at any time
Fast remediation	Critical vulnerabilities on internet-facing systems remediated	≤ 14 days
Recoverable backend	Quarterly restore tests meeting RTO 4 h and RPO 1 h	4 of 4 per year
MFA everywhere	Remote and privileged access protected by multi-factor authentication	100 %
Reviews on time	Documents and controls reviewed by their due date	≥ 95 %

Risk-based approach

- **ISMS-3** Security decisions shall be based on the information security risk assessment and the risk criteria defined in PROC-RISK. The Statement of Applicability records which Annex A controls apply, why, and how they are implemented.
- **ISMS-4** Risks above the appetite defined in the risk criteria shall be treated. Residual risk shall be retained only by the role the criteria name for the respective band, and the decision shall be recorded.

Legal and contractual requirements

- **ISMS-5** PaketPort shall identify and meet the legal, regulatory and contractual requirements that apply to each entity, in particular the NIS2 Directive, the General Data Protection Regulation, the Cyber Resilience Act for the locker product line and the security annexes of carrier agreements. The requirements are maintained in the legal register and governed by POL-LEG.

Roles and accountability

- **ISMS-6** The Managing Director is accountable for information security in the group. The Information Security Officer / ISMS Manager establishes, operates and reports on the ISMS. Every document, control, risk and asset has an owner role as defined in POL-ORG.
- **ISMS-7** Managers at every level shall ensure that the people in their area know the policies that concern them, have the time and tools to apply them, and are held to them.

The policy framework

- **ISMS-8** This policy is implemented through topic-specific policies, standards and procedures created and controlled under PROC-DOC. The topics covered are: organisation and roles, acceptable use, asset management and classification, access control, cryptography, supplier and cloud security, incident management, business continuity, people security and awareness, physical security, secure development, vulnerability and configuration management, logging and monitoring, network security, remote working, and legal and privacy compliance. The document register published with every release lists the current documents and their versions.

Everyone's duties

- **ISMS-9** Everyone with access to PaketPort information or systems shall follow the policies that apply to them, complete the training assigned to their role, protect their credentials and devices, and report suspected security events without delay through the channels defined in POL-IR.
- **ISMS-10** Breaches of this policy or of the policies under it may lead to disciplinary measures under POL-HR and, for contractors and suppliers, to the consequences set out in their agreements.

Assurance and continual improvement

- **ISMS-11** The ISMS shall be audited internally at least once a year (PROC-AUDIT), reviewed by top management at least once a year (PROC-MR) and improved through corrective actions (PROC-CAPA). Audit results and the status of objectives shall be reported to the Managing Director.
- **ISMS-12** This policy shall be reviewed at least annually and after significant changes to the organisation, its services or its legal environment. It is approved by the Managing Director, published to all staff and made available on request to customers, carriers, authorities and the certification body.

Roles and responsibilities

Role	Responsibility
Managing Director	Accountable for information security; approves this policy, the risk criteria and the retention of medium and high residual risks; chairs the management review
Information Security Officer / ISMS Manager	Operates the ISMS, maintains the policy framework and the Statement of Applicability, reports on objectives, audits and incidents
Country Manager Germany, Site Lead Brno	Apply this policy and the framework at their entity and report local issues and regulatory contacts to the ISMS Manager
Heads of function (Platform & SRE, IT Operations, Software Engineering, Procurement, HR, Facilities)	Own the policies and controls of their area and ensure their teams apply them
Data Protection Officer	Advises on personal-data protection and reports independently to the Managing Director
All staff, technicians and contractors	Follow the applicable policies, complete training, report events

Compliance and exceptions

Compliance with this policy is measured through the objectives in ISMS-2, the internal audit programme and the management review. No exceptions to this policy are granted. Exceptions to the topic-specific policies follow the exception path described in PROC-DOC: a control exception request approved by the document owner and the ISMS Manager, time-limited to at most twelve months and recorded in the exception register.

Related documents

- POL-ORG — Information Security Roles and Governance Policy
- PROC-RISK — Risk Assessment and Treatment Procedure
- PROC-MR — Management Review Procedure
- PROC-AUDIT — Internal Audit Procedure
- PROC-CAPA — Nonconformity and Corrective Action Procedure
- PROC-DOC — Document Control Procedure
- POL-IR — Information Security Incident Response Policy

- POL-HR — HR Security & Awareness Policy
- POL-LEG — Legal, Regulatory and Privacy Compliance Policy

Revision history

Version	Approved	Changes
2.0.0	2025-09-01	Rewritten for ISO/IEC 27001:2022 and the NIS2 Directive; the scope now covers the group; ISMS-2 now carries the objectives table with measures and targets agreed at the management review.; Statement ids ISMS-1 to ISMS-12 introduced; ISMS-8 lists the topics of the policy framework.; The detailed description of roles, committees and reporting lines, which moved to POL-ORG.
1.2.0	2024-09-02	Periodic review: references to the ISO/IEC 27001:2013 control set replaced by the 2022 Annex A;
1.1.0	2023-09-04	Duty of all staff to report suspected security events through the incident channels.; Objectives for 2023/24 updated following the first internal audit.
1.0.0	2022-09-05	Initial approved version (imported from the previous document management system).

Approval and control

Approved by the Managing Director (Dana Weber) on 2025-09-01; owned by the Information Security Officer / ISMS Manager (Alex Rossi). The approval is recorded in version control as the reviewed and merged pull request of this version (PROC-DOC, stage 3).

Source digest sha256:8f96c01d1ee0829b7d819adde4910493a90efc651dff88f8739caa0026f3e31d · rendered by isms-as-code from the repository sources.